



PES UNIVERSITY, BANGALORE

Department of Computer Science and Engineering



Software Requirements Specification

Online Bookstore

Version 1.1 approved

Prepared by Group 2

Chenchu Sreekrishna Koushik - PES1UG24CS128

Deeptha S - PES1UG24CS144

G H Pramod - PES1UG24CS162

Hardhick M Gowda - PES1UG24CS179

PES University, Bengaluru | UE24CS341A Software Engineering, Section C

5 October 2026



PES UNIVERSITY, BANGALORE

Department of Computer Science and Engineering



Table of Contents

1. Introduction.....	4
1.1 Purpose.....	4
1.2 Intended Audience.....	4
1.3 Product Scope.....	4
1.4 References.....	4
2. Overall Description.....	6
2.1 Product Perspective.....	6
2.2 Product Functions.....	6
2.3 User Classes and Characteristics.....	7
2.4 Operating Environment.....	7
2.5 Design and Implementation Constraints.....	7
2.6 Assumptions and Dependencies.....	8
3. External Interface Requirements.....	9
3.1 User Interfaces.....	9
3.2 Software Interfaces.....	9
3.3 Communications Interfaces.....	10
3.4 Hardware Interfaces.....	10
4. Analysis Models.....	11
4.1 Use Case Diagram.....	11
4.2 Entity-Relationship Diagram.....	12
5. System Features.....	13
5.1 Identity, Accounts and Access Control.....	13
5.2 Catalogue, Search and Reviews.....	14
5.3 Cart, Checkout, Payment and Orders.....	15
5.4 Seller Operations, Administration and Reporting.....	16
6. Other Nonfunctional Requirements.....	18
6.1 Performance Requirements.....	18
6.2 Safety Requirements.....	18
6.3 Security Requirements.....	18
6.4 Software Quality Attributes.....	20
6.5 Business Rules.....	21
7. Other Requirements.....	22
7.1 Database Requirements.....	22
7.2 Legal and Compliance Requirements.....	22
7.3 Reuse Objectives.....	22
Appendix A: Glossary.....	23
Appendix B: Field Layouts and Report Requirements.....	24
Appendix C: Requirement Traceability Matrix.....	27



PES UNIVERSITY, BANGALORE

Department of Computer Science and Engineering



Revision History

Name	Date	Reason For Changes	Version
Group 2	02 Sep 2026	Initial draft prepared from the assigned project brief.	0.1
Group 2	06 Sep 2026	Requirements itemised as FR-01 to FR-24 and NFR-01 to NFR-08; product ownership assigned.	0.5
Group 2	10 Sep 2026	Analysis models, field layouts and traceability matrix added; document approved as the baseline for Sprint 1.	1.0
Group 2	05 Oct 2026	Review against the Part-1 deliverables: security objectives SO-01 to SO-05 and requirements SR-01 to SR-12 added; schema completed to seventeen collections; session model made consistent; use case and ER diagrams corrected; BR-02 enforced in FR-15; performance targets identified. Document restructured to follow the course SRS template (definitions moved to Appendix A; design references added to the traceability matrix).	1.1

1. Introduction

1.1 Purpose

This document specifies the software requirements for the Online Bookstore, version 1.0 - a web-based marketplace on which buyers purchase books and on which sellers list new and second-hand copies for sale. The specification covers the entire system: the React client, the Express service layer, the MongoDB data store and the interfaces to the external payment gateway and e-mail service. No part of the product is described in a separate specification.

The requirements stated here are the agreed baseline for implementation. Requirements FR-01 to FR-24 and NFR-01 to NFR-08 are the complete, frozen scope of version 1.0; anything not stated here is out of scope until a revision entry is recorded in the revision history above.

1.2 Intended Audience

This specification is written for the four developers of Group 2, who implement and test the system; for the course faculty, who evaluate it; and for the testers among the team, who derive test cases from it. It is also intended to remain readable by a non-technical reviewer down to the end of Section 2.

Suggested reading order. A reviewer new to the project should read Section 1 and Section 2 for the problem and its context, then Section 4 for the analysis models, and stop there. A developer should read Section 5 for the behaviour they must build and Section 3 for the interfaces they must respect. A tester should read Section 5 together with Section 6, and then Appendix C, which maps every requirement to the test case that closes it. A reader concerned only with data structures should go directly to Appendix B.

1.3 Product Scope

The Online Bookstore replaces the informal, unrecorded trade in second-hand books - conducted today over messaging groups and physical notice boards - with a searchable catalogue, a protected payment path and an auditable order record. It also serves new stock, so a seller need not keep two channels.

The system's objectives are: to let a buyer find a specific title and compare every available offer for it in under a minute; to let a seller list a copy in under two minutes and be paid without chasing anyone; to leave a complete, auditable record of every order and payment; and to do all of this without the platform ever storing card data.

Out of scope for version 1.0: real-money payment settlement, physical logistics integration beyond recording a courier tracking number, a mobile application, multi-language content, seller-to-seller bulk trade, and any recommendation engine based on machine learning.

1.4 References

- IEEE Std 830-1998, IEEE Recommended Practice for Software Requirements Specifications, on which the structure of this document is based.
- Project Guidelines issued for UE24CS341A, Semester V 2026, which define the required proposal contents and the product ownership expectation.
- Group 2 Project Proposal, Online Bookstore, version 1.0, 10 September 2026 - the source of the plan of work and the ownership split in this document.

- Appendix B - Field Layouts and Report Requirements (Excel workbook), which carries the full data dictionary summarised in Section 7.
- Appendix C - Requirement Traceability Matrix (Excel workbook), which traces every requirement in this document to architecture, design, code and test.
- MongoDB Manual - Text Indexes and Aggregation Pipeline, used for the search design underlying FR-08 and NFR-01.
- OWASP Top 10 (2021), used as the checklist for the security review underlying NFR-03.

2. Overall Description

2.1 Product Perspective

The Online Bookstore is a new, self-contained product. It is not a member of a product family and it does not replace an existing system, although it does displace an informal manual practice. It is built as a three-tier web application: a React single-page client, a Node.js and Express REST service layer, and a MongoDB data store, with Redis used for query caching and login rate-limit counters. Access tokens are stateless JWTs; refresh-token sessions are persisted in MongoDB.

Two external systems sit outside the trust boundary. A payment gateway, used in sandbox mode, performs authorisation and capture, so that no card data ever enters the application. An SMTP e-mail service delivers OTPs, order confirmations, invoices and low-stock alerts. The system depends on both being reachable but degrades predictably when they are not: a failed payment leaves the order in the PLACED state rather than confirming it, and a failed notification is queued and retried up to three times.

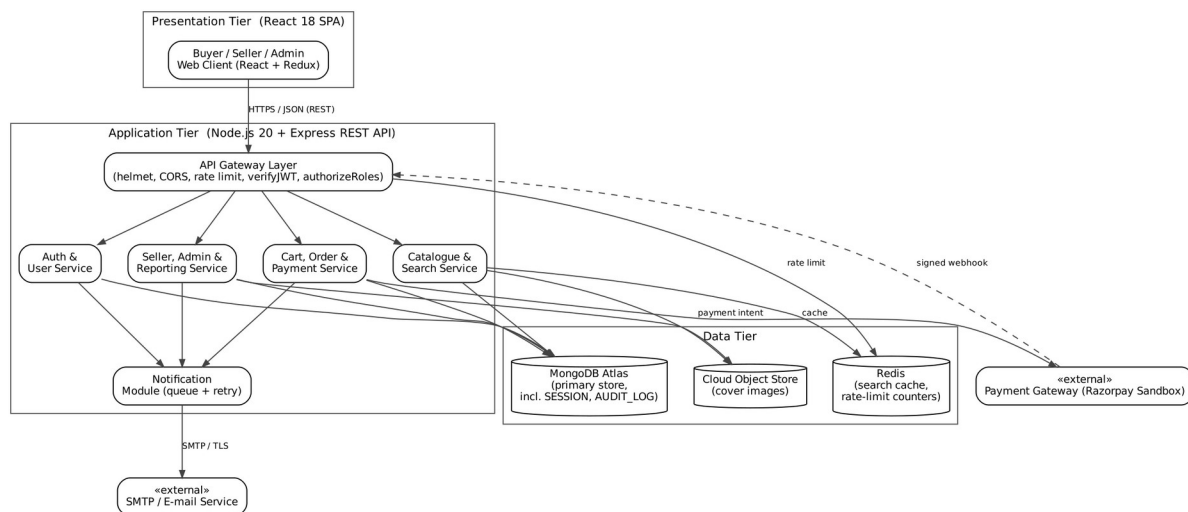


Figure 1: System architecture - tiers, services and external interfaces

2.2 Product Functions

At a high level, the product performs the following groups of functions. Each is specified in detail in Section 5.

- Account and access management - registration, e-mail verification, authenticated sessions, password recovery, profile and address maintenance, and role-based authorisation across Buyer, Seller and Administrator.
- Catalogue and discovery - a paged catalogue, keyword search, filtering and sorting, a detail page aggregating every seller offer for a title, verified-purchase reviews and related-title suggestions.
- Purchase pipeline - cart and wishlist, checkout with delivery address and coupons, gateway-backed payment with retry, invoice generation, and order tracking with cancellation and return.
- Seller operations - listing creation from an ISBN lookup, stock and price management with low-stock alerting, order fulfilment through dispatch, and a sales and settlement dashboard.

- Administration and reporting - moderation of listings, users and reviews; platform analytics; and export of any report to CSV or PDF.

2.3 User Classes and Characteristics

User class	Frequency of use	Technical expertise	Functions used	Privilege
Buyer	Occasional - a few visits per month	General web literacy; no training assumed	Search, browse, cart, checkout, payment, order tracking, reviews	Own data only
Seller	Frequent - several visits per week	General web literacy; may be a first-time online seller	Listing and inventory management, fulfilment, sales dashboard	Own listings and orders
Administrator	Daily but brief	Technically competent operator	Moderation, user management, platform analytics and exports	Full privilege across the platform
Guest (unregistered visitor)	Variable	General web literacy	Browse and search the catalogue and view book details only	Read-only, no account

The Buyer class is the most important to satisfy because it is the largest and the least tolerant of friction. A single person may hold both the Buyer and Seller roles on one account; the Administrator role is never combined with either. Administrator accounts cannot be self-registered: the first is seeded at deployment and further ones are created only by an existing administrator.

2.4 Operating Environment

- Client - the latest two major versions of Chrome, Edge, Firefox and Safari, on Windows 10 or later, macOS 13 or later, Ubuntu 22.04 or later, and on Android and iOS mobile browsers down to a 360 px viewport.
- Server - Node.js 20 LTS on a Linux container, deployed to a managed cloud host.
- Database - MongoDB 7 on a managed Atlas cluster; Redis 7 for sessions and caching.
- Network - HTTPS over TLS 1.2 or higher for all client-server traffic; outbound HTTPS to the payment gateway and outbound SMTP over TLS to the e-mail service.
- Coexistence - the application shares its host with no other tenant application and makes no assumption about local file storage; cover images are held in a cloud object store.

2.5 Design and Implementation Constraints

ID	Constraint	Origin
DC-01	The implementation stack is fixed to MERN - MongoDB, Express.js, React and Node.js.	Project brief issued to Group 2
DC-02	Payment is restricted to the gateway's sandbox mode; no real money is settled and no card data may be stored by the application.	Course policy and PCI-DSS scope avoidance
DC-03	All third-party services must remain within their free tiers, which caps	Team resources

ID	Constraint	Origin
	cluster storage, e-mail volume and container memory.	
DC-04	The system must be delivered, tested and demonstrated within one semester by four part-time developers.	Course calendar
DC-05	All source is held in a single GitHub repository with protected main; every change reaches main through a reviewed pull request that passes the CI gates.	Team process agreement
DC-06	Code must satisfy ESLint with zero errors, and service modules must hold at least 70 per cent unit-test coverage.	NFR-06, enforced in CI
DC-07	Prices and settlements are held in Indian Rupees to two decimal places; timestamps are stored in UTC and rendered in IST.	Target market

2.6 Assumptions and Dependencies

- It is assumed that the payment gateway sandbox remains available throughout the project and that its callback behaviour mirrors production closely enough for the order pipeline to be validated against it.
- It is assumed that sellers describe a book's condition honestly. The system records the declared condition and supports a return, but it cannot verify a physical claim.
- It is assumed that a seller arranges physical dispatch through a courier and enters the tracking number; the system does not book or price logistics.
- It is assumed that ISBN-13 uniquely identifies a title for cataloguing purposes, and that a title without an ISBN - a rare, older or self-published book - is entered manually by an administrator.
- The system depends on the SMTP service for OTP delivery. If it is unreachable, registration cannot complete; this is mitigated by queueing and up to three retries, and by surfacing a resend action to the user.
- The system depends on MongoDB Atlas and Redis being reachable. Loss of Redis degrades performance but not correctness, because the cache is read-through and refresh-token sessions are held in MongoDB rather than in Redis.
- It is assumed that the evaluation load is at most 200 concurrent users against a seeded catalogue of 10,000 listings, which is the basis of the performance target in NFR-01.

3. External Interface Requirements

3.1 User Interfaces

The client is a single-page React application presenting three surfaces - buyer, seller and administrator - built from one shared component library so that the visual language is common to all three. The following characteristics apply to every screen.

- A persistent header carries the search box, the cart indicator and the account menu. The search box is reachable from every buyer-facing screen without navigation.
- The layout is responsive down to a 360 px viewport, with the catalogue grid collapsing from four columns to one.
- Every destructive action - unlisting, cancelling, blocking - requires a confirmation step naming the object being acted upon.
- Errors are reported inline against the field that caused them, and never as a bare status code. A failed payment states what happened and offers a retry.
- Text and background contrast meets WCAG 2.1 level AA, and every interactive control is reachable by keyboard with a visible focus indicator.
- A standard help affordance appears in the header of the seller and administrator surfaces.

The principal screens are: Home and catalogue, Search results with the filter panel, Book detail with seller offers, Cart, Checkout, Order confirmation, Order history and tracking, Seller listing form, Seller inventory, Seller dashboard, Administrator moderation queue, and Administrator analytics. Wireframes WF-01 to WF-08 accompany this specification in the repository.

3.2 Software Interfaces

Interface	Version / Mode	Data in	Data out	Purpose
MongoDB Atlas	MongoDB 7, via Mongoose 8	Document reads and writes over the Mongoose ODM	Query results, aggregation output	Primary persistent store for all collections in Appendix B
Redis	Redis 7	Cached filter results, rate-limit counters	Cached values, counter values	Query caching for NFR-01 and login rate limiting for SR-10
Payment gateway	Sandbox REST API	Order amount, currency, order reference	Payment intent, gateway transaction reference, callback with final status	Authorisation and capture for FR-16
SMTP e-mail service	SMTP over TLS	Recipient, subject, rendered template	Delivery acknowledgement or failure code	OTP, order confirmation, invoice and alert delivery
Cloud object store	HTTPS REST	Cover image binary	Public image URL	Storage and retrieval of cover images

The application exposes its own REST API over HTTPS. Requests and responses are JSON. Authenticated calls carry a bearer JWT in the Authorization header. Errors are returned with an appropriate HTTP status and a body carrying a stable error code and a human-readable message. The full contract is maintained as an OpenAPI document in the repository and is owned by the integration lead.

3.3 Communications Interfaces

- All client-server communication is over HTTPS with TLS 1.2 or higher. Plain HTTP requests are redirected permanently to HTTPS.
- The payment gateway calls back to a dedicated webhook endpoint. The callback signature is verified before the payload is trusted, and the handler is idempotent so that a repeated callback cannot confirm an order twice.
- Outbound e-mail is sent over SMTP with STARTTLS. Messages are queued, and a failed send is retried up to three times with exponential backoff before being marked FAILED.
- Session state is carried in a JWT rather than in a cookie-bound server session, so that the service layer remains stateless and horizontally scalable.
- Cross-origin requests are accepted only from the deployed client origin, enforced by an explicit CORS allow-list.

3.4 Hardware Interfaces

The system requires no dedicated hardware interface. It runs on commodity cloud containers and is reached from a standard web browser on a personal computer or a mobile device. No scanner, card reader, printer driver or other peripheral is addressed directly; an invoice is produced as a PDF and printed, if at all, by the user's own browser.

4. Analysis Models

4.1 Use Case Diagram

The use case diagram below shows the four human actors - Guest, Buyer, Seller and Administrator - and the two external systems, together with the sixteen use cases inside the system boundary. Payment is included by order placement, and notification is included by both order placement and fulfilment; viewing a book's detail extends browsing the catalogue.

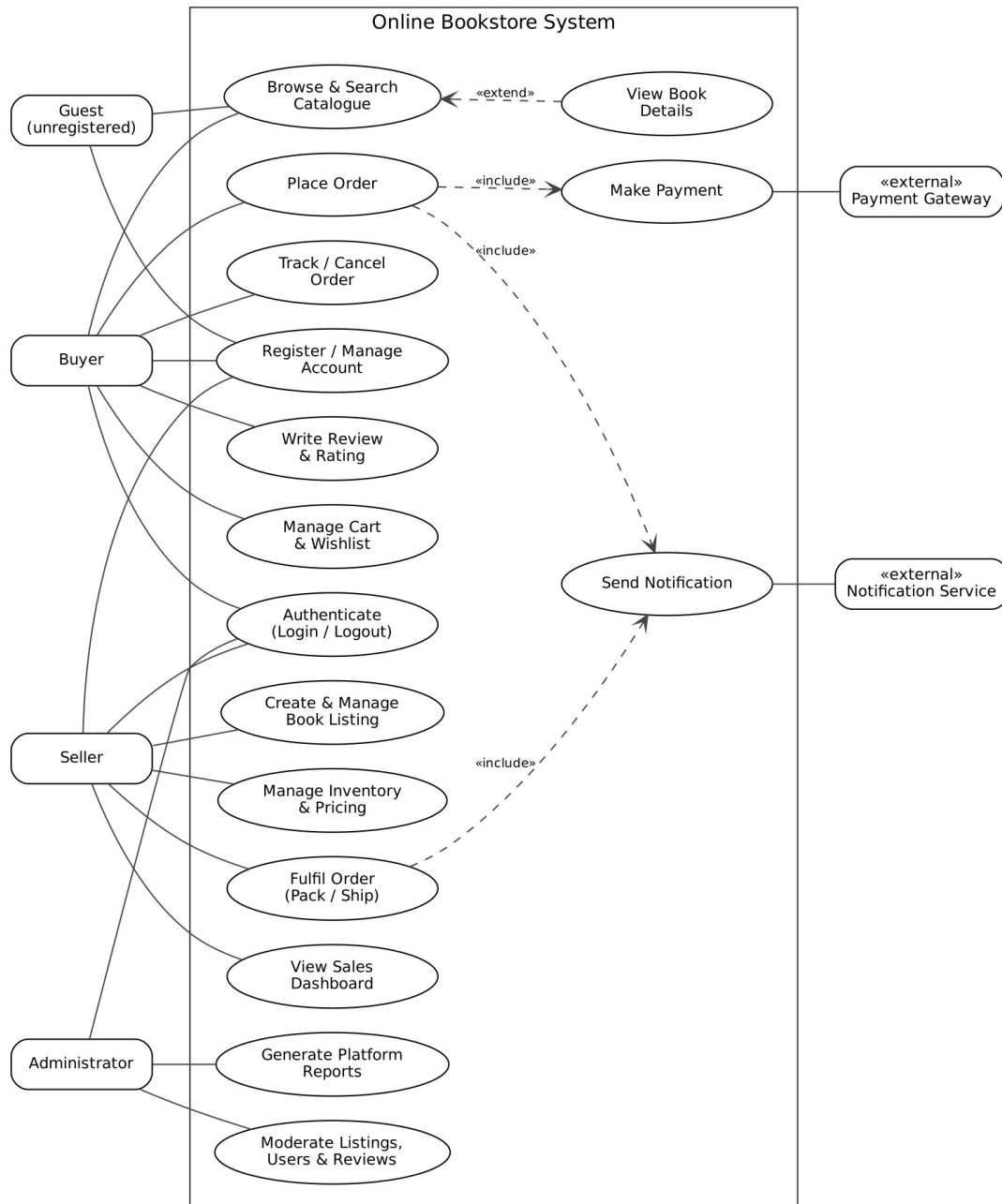


Figure 2: Use case diagram - Online Bookstore

4.2 Entity-Relationship Diagram

The entity-relationship diagram shows the seventeen persistent collections and the relationships between them. USER is deliberately a single collection carrying a role attribute rather than three separate collections, because one person may act as both buyer and seller. LISTING is the join between a catalogue title and a seller, and is what a cart line and an order line actually reference - so a later price change by the seller cannot alter the price already recorded against a placed order. Field-level detail for every entity appears in Appendix B.

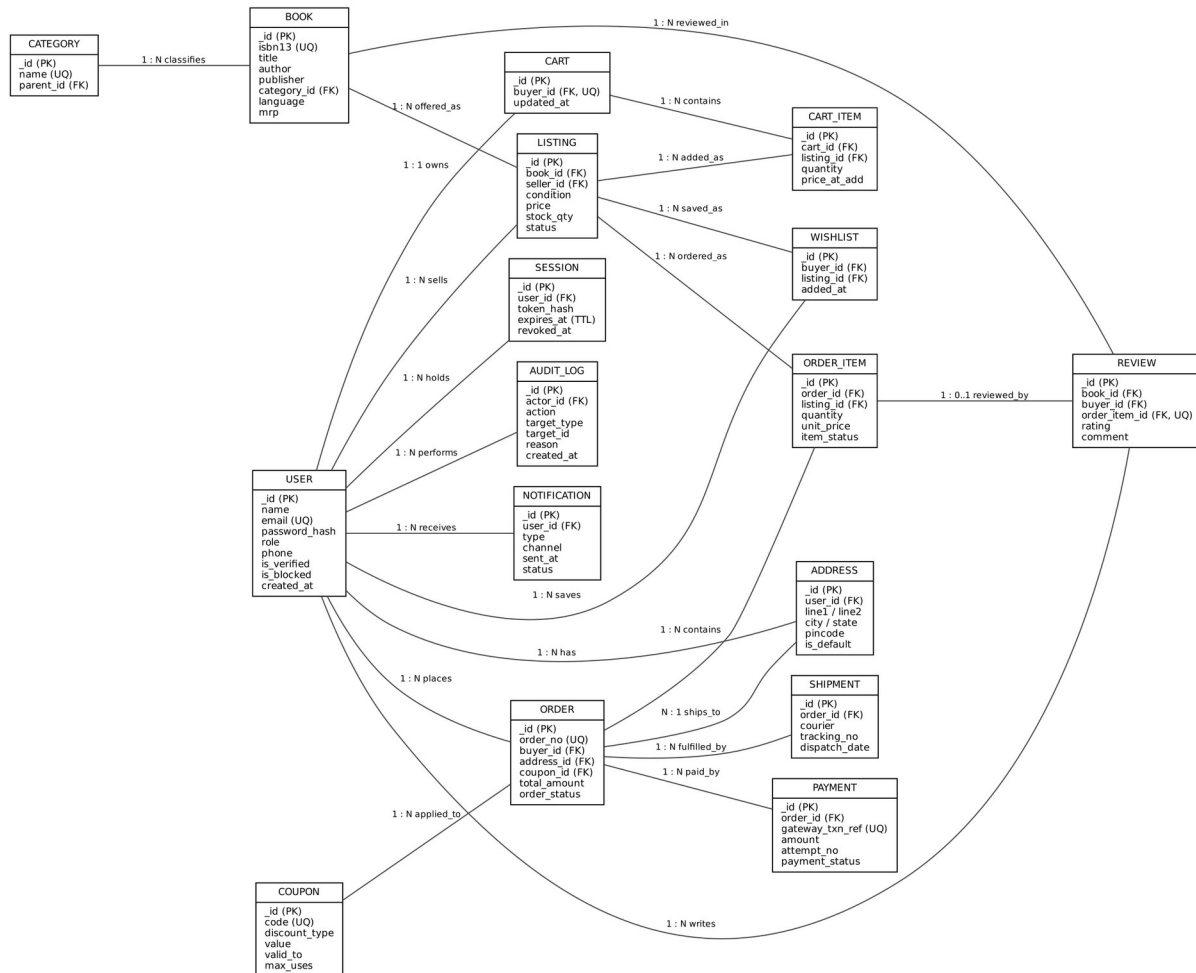


Figure 3: Entity-relationship diagram - Online Bookstore

5. System Features

The functional requirements are organised below by system feature. Each feature corresponds to one module of the system and to one accountable owner, as agreed in the project proposal. Priority is stated as High, Medium or Low, where High means the feature must be present for the system to be demonstrable at all.

5.1 Identity, Accounts and Access Control

Owner: Chenchu Sreekrishna Koushik (PES1UG24CS128)

5.1.1 Description and Priority

This feature admits users to the system and governs what each may do once inside. It covers registration as a buyer or a seller, verification of the e-mail address, authenticated sessions, password recovery, maintenance of the profile and address book, and the authorisation check applied to every protected route. Nothing else in the system can be trusted unless this feature is correct, which is why it is built first.

Priority: High

5.1.2 Stimulus / Response Sequences

- Stimulus: a visitor submits the registration form. Response: the system validates the input, rejects a duplicate e-mail with a field-level message, creates the account in an unverified state, and e-mails a six-digit OTP valid for ten minutes.
- Stimulus: the user submits the OTP. Response: on a match the account is activated and the user is signed in; after three wrong attempts the code is invalidated and a fresh one must be requested.
- Stimulus: a registered user submits valid credentials. Response: the system issues a 15-minute access token and a 7-day refresh token and returns the user's role.
- Stimulus: a request arrives with an expired access token. Response: the client silently exchanges the refresh token; if the refresh token is also expired the user is returned to the login screen with their intended destination preserved.
- Stimulus: a buyer calls a seller-only endpoint. Response: the request is refused with HTTP 403 and the attempt is written to the audit log.
- Stimulus: a user requests a password reset. Response: a single-use link valid for thirty minutes is e-mailed; the same confirmation message is shown whether or not the address is registered, so that the form cannot be used to enumerate accounts.

5.1.3 Functional Requirements

FR-01: The system shall allow a visitor to register as a Buyer or a Seller, capturing name, e-mail, phone and password. The e-mail must be unique and RFC-5322 valid, the phone exactly ten digits, and the password at least eight characters with an upper-case letter, a lower-case letter, a digit and a symbol. All validation is repeated server-side.

FR-02: The system shall e-mail a six-digit OTP on registration and shall activate the account only when that OTP is entered within ten minutes. An unverified account may not sign in, and the user may request a new code at most three times per hour.

FR-03: The system shall authenticate a verified user against a bcrypt hash and issue a JWT access token expiring in 15 minutes together with a refresh token expiring in 7 days. Logout shall invalidate the refresh token immediately.

FR-04: The system shall provide password recovery through a single-use link valid for thirty minutes, and shall invalidate all outstanding refresh tokens for that account once the password is changed.

FR-05: The system shall allow a signed-in user to view and edit their profile, and to add, edit and delete delivery addresses, exactly one of which is marked default. The last remaining address may not be deleted while an order is in flight against it.

FR-06: The system shall enforce role-based access control on every protected route, admitting only the roles declared for that route and refusing all others with HTTP 403. An account blocked by an administrator shall be refused at authentication, whatever its role.

5.2 Catalogue, Search and Reviews

Owner: Deeptha S (PES1UG24CS144)

5.2.1 Description and Priority

This feature is how a buyer finds a book. It covers the paged catalogue, keyword search across the fields a reader is likely to remember, filtering and sorting, and the detail page that gathers every active seller offer for a title so that the buyer can compare on condition and price. It also covers reviews, which are permitted only against a delivered purchase, and related-title suggestions. This feature carries the system's most visible performance target.

Priority: High

5.2.2 Stimulus / Response Sequences

- Stimulus: a visitor opens the catalogue. Response: the first twenty titles are returned with cover, title, author, lowest active offer price and average rating, with paging controls.
- Stimulus: a user types a keyword and submits. Response: the system runs a text-index search across title, author, ISBN-13 and publisher and returns ranked results within two seconds; if nothing matches, it says so plainly and offers the nearest category.
- Stimulus: a user applies a filter or changes the sort. Response: the result set is re-queried server-side, the page resets to one, and the active filters remain visible and individually removable.
- Stimulus: a user opens a title. Response: the detail page shows the metadata and every ACTIVE listing for that title, ordered by price ascending, each with its condition, seller and stock state.
- Stimulus: a buyer submits a review for a title they have not received. Response: the submission is refused, stating that only a delivered purchase may be reviewed.
- Stimulus: a buyer submits a valid review. Response: the review is stored, the title's average rating and review count are recalculated, and the review appears attributed to the buyer's display name.

5.2.3 Functional Requirements

FR-07: The system shall present the catalogue with server-side pagination of twenty titles per page, showing cover image, title, author, lowest active price and average rating for each title.

FR-08: The system shall support keyword search across title, author, ISBN-13 and publisher using a compound text index, ranking results by text score and returning them within the limit set by NFR-01.

FR-09: The system shall allow results to be filtered by category, price range, condition, language and minimum rating, in any combination, and sorted by price ascending or descending, by average rating or by recency of listing.

FR-10: The system shall present a book detail page carrying full metadata and every listing with status ACTIVE for that title, ordered by price ascending, each showing condition, seller display name and stock availability.

FR-11: The system shall accept an integer rating from 1 to 5 and an optional comment of up to 1000 characters, only from a buyer holding an order line for that title with item status DELIVERED, and at most one review per order line. The title's average rating shall be recalculated on acceptance.

FR-12: The system shall display up to six related titles on the detail page, drawn from the same author first and then the same category, excluding the title being viewed and any title with no active listing.

5.3 Cart, Checkout, Payment and Orders

Owner: G H Pramod (PES1UG24CS162)

5.3.1 Description and Priority

This feature carries the buyer from intent to a paid, tracked order. It covers the cart and wishlist, checkout against a saved address with optional coupon, payment through the gateway with reconciliation and retry, invoice generation, and the order lifecycle through to cancellation or return. It is the feature where money and stock must stay in agreement, and it therefore carries the system's data-integrity target.

Priority: High

5.3.2 Stimulus / Response Sequences

- Stimulus: a buyer adds an offer to the cart. Response: the line is created with the current price captured against it; if the requested quantity exceeds available stock the system caps it and says so.
- Stimulus: a buyer returns after logging out and back in. Response: the cart is restored intact, with any line whose listing is no longer ACTIVE flagged and excluded from the total.
- Stimulus: a buyer starts checkout. Response: the system revalidates every line against current price and stock, presents the delivery address choice, accepts a coupon code and shows the payable summary before anything is charged.
- Stimulus: the buyer confirms payment and the gateway reports success. Response: the system verifies the callback signature, decrements stock atomically, moves the order to CONFIRMED, generates the invoice and e-mails it.
- Stimulus: the gateway reports failure. Response: the order remains PLACED, no stock is decremented, the failure reason is shown, and up to two further attempts are permitted.
- Stimulus: the gateway repeats a callback already processed. Response: the handler recognises the transaction reference and returns success without changing anything.
- Stimulus: a buyer requests cancellation. Response: the request is accepted while the order has not been dispatched, stock is returned to the listing, and a refund is raised; after dispatch the buyer is offered a return instead.

5.3.3 Functional Requirements

FR-13: The system shall allow a buyer to add a listing to the cart, change the quantity between 1 and 10 subject to available stock, and remove a line. The cart shall persist against the buyer's account across sessions and devices.

FR-14: The system shall allow a buyer to save a listing to a wishlist and to move a wishlist item into the cart in a single action, removing it from the wishlist on success.

FR-15: The system shall present a checkout that revalidates every cart line against current price and stock, requires the selection of a delivery address, accepts an optional coupon code, and displays item total, shipping fee, discount and payable amount before confirmation. Shipping shall be waived where the item total is 500 rupees or more. A line whose listing belongs to the buyer shall be refused at checkout (BR-02).

FR-16: The system shall create a payment intent with the gateway for the payable amount, shall confirm the order only on a signature-verified success callback, and shall permit at most three payment attempts per order. The callback handler shall be idempotent.

FR-17: The system shall generate a PDF invoice on confirmation, carrying the order number, buyer and delivery details, every line with unit price and line total, and the tax summary; the invoice shall be downloadable and shall be e-mailed to the buyer.

FR-18: The system shall expose the order lifecycle - PLACED, CONFIRMED, PACKED, SHIPPED, DELIVERED, CANCELLED, RETURNED - to the buyer with its timestamps and tracking number, shall accept cancellation until dispatch, and shall accept a return request within seven days of delivery.

5.4 Seller Operations, Administration and Reporting

Owner: Hardhick M Gowda (PES1UG24CS179)

5.4.1 Description and Priority

This feature is the supply side of the marketplace and the platform's control surface. It covers listing creation and maintenance, stock and price management with low-stock alerting, order fulfilment through dispatch, and the seller's sales and settlement dashboard. It also covers the administrator's moderation of listings, users and reviews, and the platform analytics that are exported for reporting.

Priority: High

5.4.2 Stimulus / Response Sequences

- Stimulus: a seller enters an ISBN-13 on the listing form. Response: the system finds the catalogue title and auto-fills the metadata, or invites the seller to enter it manually where no such title exists.
- Stimulus: a seller saves a listing with a price above the printed MRP. Response: the save is refused with the reason stated.
- Stimulus: stock on a listing falls to five units or fewer. Response: a low-stock alert is raised to the seller and the listing is flagged on the inventory screen.
- Stimulus: stock reaches zero. Response: the listing status changes automatically to OUT_OF_STOCK and it disappears from buyer-facing results without being deleted.
- Stimulus: a seller marks an order line dispatched and enters courier and tracking number. Response: a shipment record is created, the order line moves to SHIPPED and the buyer is notified.

- Stimulus: an administrator blocks a listing. Response: the listing is withdrawn from all buyer-facing results immediately, the seller is notified with the reason, and the action is written to the audit log.
- Stimulus: an administrator requests the monthly platform report. Response: the system aggregates the period and returns it on screen with an export to CSV or PDF.

5.4.3 Functional Requirements

FR-19: The system shall allow a seller to create a listing against an ISBN-13, auto-filling catalogue metadata where the title exists, and to capture condition, price, MRP and stock quantity. The seller shall be able to edit and to unlist, but never to delete, a listing that carries order history.

FR-20: The system shall allow a seller to update stock and price on an active listing, shall refuse a price above the recorded MRP, shall raise a low-stock alert at five units or fewer, and shall set the status to OUT_OF_STOCK automatically at zero.

FR-21: The system shall allow a seller to accept an order line, mark it packed, and record courier name and tracking number on dispatch, creating a shipment record and notifying the buyer at each transition.

FR-22: The system shall present a seller dashboard giving units sold, gross revenue, returns, platform commission and net settlement for a date range chosen by the seller, with the underlying orders listed beneath the summary.

FR-23: The system shall allow an administrator to review reported listings, users and reviews, and to block or unblock each, recording actor, reason and timestamp for every action in the audit log.

FR-24: The system shall present platform analytics to an administrator - orders placed, delivered and cancelled, gross merchandise value, commission earned, average order value and new-user growth - for a chosen month, exportable to CSV and PDF.

6. Other Nonfunctional Requirements

6.1 Performance Requirements

Performance targets are stated against a defined load so that they can be tested rather than argued about. The reference load is 10,000 seeded listings and 200 concurrent users, which is the scale at which the system is demonstrated.

- NFR-01: A catalogue search shall return results within 2 seconds at the 95th percentile under the reference load. The search shall use a compound text index and shall not perform a collection scan; the query plan is verified as part of the test. Repeated filter combinations are served from a Redis cache with a five-minute time to live.
- PERF-02: A catalogue page and a book detail page shall render within 3 seconds at the 95th percentile under the reference load.
- PERF-03: Adding an item to the cart shall complete within 1 second, since it is the most frequent write in the buying path.
- PERF-04: Order confirmation, which includes the gateway round trip, shall complete within 8 seconds, of which no more than 2 seconds is the system's own processing.
- PERF-05: Report generation over a one-month period shall complete within 10 seconds and shall be executed as a database aggregation rather than in application memory.

6.2 Safety Requirements

The system is a commercial web application and carries no risk of physical harm. The losses it must guard against are financial and informational.

- No stock shall be decremented until the payment gateway has confirmed a successful capture, so that a buyer cannot be charged for a copy that was not reserved, nor a copy reserved for a payment that never completed.
- A listing shall never be permanently deleted once it carries order history; it is unlisted instead, so that an audit trail survives.
- No order, payment or shipment record shall be hard-deleted by any user, including an administrator. Corrections are made by a compensating record.
- A destructive action shall require explicit confirmation naming the object being acted upon.
- Database backups shall be taken daily by the managed service, and a restore shall be rehearsed once before the demonstration.

6.3 Security Requirements

Security is specified in two layers: the objectives the platform must achieve, and the verifiable requirements that realise them. Each requirement names the objective it serves. NFR-03 and NFR-08 keep their original identifiers, as SR-01 and SR-09, so that the traceability matrix in Appendix C remains valid; the remaining SR requirements are traced in the Software Architecture and Design Specification (section 3.9) and the Software Test Plan (section 5.1).

6.3.1 Security Objectives

ID	Objective	Statement	Assets protected
SO-01	Confidentiality of personal and credential data	Only the owning user - or an administrator acting on a recorded duty - can read a user's personal data, and no credential can be recovered from storage or logs.	USER, ADDRESS, SESSION
SO-02	Integrity of orders, payments and stock	No order is confirmed, no stock decremented and no price changed except through an authenticated, validated path; payment state changes only on a verified gateway callback.	ORDER, PAYMENT, LISTING
SO-03	Authenticated, least-privilege access	Every request is attributable to a verified identity, and each role reaches only the functions declared for it.	All protected routes
SO-04	Accountability	Every administrative action and payment event can be traced to an actor and a time, and cannot be altered afterwards.	AUDIT_LOG, PAYMENT
SO-05	Resilience to abuse	Brute-force, enumeration and flooding attempts cannot lock out legitimate users or exhaust the free-tier resources the system runs on.	Auth endpoints, OTP, search

6.3.2 Security Requirements

ID	Requirement	Objective served
SR-01 (NFR-03)	Passwords shall be stored only as bcrypt hashes at cost factor 12. Plaintext passwords shall never be logged, echoed in a response, or transmitted anywhere other than the login and registration endpoints over TLS.	SO-01
SR-02	All traffic shall be carried over TLS 1.2 or higher; plain HTTP shall be redirected with HTTP 301, and an HSTS header with max-age of at least 180 days shall be sent.	SO-01, SO-02
SR-03	The system shall never store, log or transmit card data. The payment gateway's hosted checkout holds all instrument details, keeping the application outside PCI-DSS scope.	SO-01
SR-04	Access tokens shall expire within 15 minutes. Refresh tokens shall be stored only as SHA-256 hashes in the SESSION collection, rotated on every use, and revoked on logout and on password change; presenting an already-rotated token shall revoke every session of that user.	SO-03
SR-05	Every protected route shall enforce role-based authorisation server-side and refuse other roles with HTTP 403, writing the refusal to the audit log. Client-side route hiding is presentation only and is never relied upon.	SO-03
SR-06	Object-level ownership shall be checked on every read and write by identifier: a buyer reaches only their own orders, addresses, cart and reviews, a seller only their own listings, orders and settlements. A request for another user's object shall return HTTP 404 so that its existence is not disclosed.	SO-01, SO-03

ID	Requirement	Objective served
SR-07	Every request body, query and parameter shall be validated against a schema that rejects unknown fields; keys beginning with \$ or containing . shall be stripped to prevent NoSQL operator injection; user-supplied text shall be encoded on output and a Content-Security-Policy header shall be sent.	SO-02
SR-08	The payment webhook shall verify the gateway's HMAC-SHA256 signature before parsing the payload, and shall ignore a callback whose gateway transaction reference has already been processed.	SO-02
SR-09 (NFR-08)	Every administrative action and every payment event shall be written to an append-only AUDIT_LOG carrying actor, action, target, reason and timestamp. No update or delete operation on the log shall be exposed by any API.	SO-04
SR-10	Failed logins shall be limited to 5 per 15 minutes per e-mail and source address, after which HTTP 429 is returned; OTP requests are capped at three per hour per account; and the password-reset response shall be identical whether or not the address is registered.	SO-05, SO-03
SR-11	Secrets - JWT signing keys, the gateway secret, database and SMTP credentials - shall be held only in environment variables or CI secrets and never committed; secret scanning runs on every pull request.	SO-01
SR-12	Before the demonstration the application shall be reviewed against the OWASP Top 10 (2021), and npm audit shall report no high or critical vulnerability in production dependencies.	SO-01 to SO-05

6.4 Software Quality Attributes

ID	Attribute	Requirement and how it is measured	Owner
NFR-02	Availability	The deployed application is reachable for at least 99 per cent of the evaluation window, evidenced by an uptime monitor polling a health-check endpoint every five minutes.	Hardhick M Gowda
NFR-04	Usability	Checkout is completed in at most four screens from cart to confirmation, and every screen is usable at a 360 px viewport. Text contrast meets WCAG 2.1 AA and all controls are keyboard reachable.	G H Pramod
NFR-05	Data integrity	Stock is decremented atomically at confirmation so that a listing cannot be oversold, demonstrated by two concurrent orders for the last copy of which exactly one succeeds.	G H Pramod
NFR-06	Maintainability	ESLint passes with zero errors and service modules hold at least 70 per cent unit-test coverage; both are CI gates that block a merge rather than conventions.	Hardhick M Gowda
NFR-07	Portability	The client renders and functions correctly on the latest two versions of Chrome, Edge, Firefox and Safari, verified by a cross-browser regression pass.	Deeptha S

ID	Attribute	Requirement and how it is measured	Owner
-	Testability	Every service module is reachable through an injected interface so that the payment gateway and the e-mail service can be stubbed in tests.	Chenchu Sreekrishna Koushik
-	Reusability	Buyer, seller and administrator surfaces are built from one shared component library rather than three parallel implementations.	Deeptha S

6.5 Business Rules

ID	Rule
BR-01	Only a buyer holding a delivered order line for a title may review that title, and only once per order line.
BR-02	A seller may not purchase their own listing.
BR-03	A listing price may not exceed the recorded MRP of the title.
BR-04	Shipping is waived where the item total reaches 500 rupees; below that a flat shipping fee applies.
BR-05	A coupon discount may not exceed the item total, and one coupon applies per order.
BR-06	An order may be cancelled by the buyer at any time before dispatch; after dispatch only a return may be raised, and only within seven days of delivery.
BR-07	Platform commission is deducted from the seller's settlement, not added to the buyer's price.
BR-08	Settlement to a seller is released only after the order line reaches DELIVERED and the return window has closed.
BR-09	Only an administrator may block or unblock a user, a listing or a review, and every such action is logged with a reason.
BR-10	A blocked user retains their order history but may neither sign in nor transact.
BR-11	A stock quantity of zero sets the listing to OUT_OF_STOCK automatically; the seller need not intervene.

Domain Requirements

- A title is identified by ISBN-13, and its checksum digit is validated on entry. A title without an ISBN is admitted only by an administrator.
- Condition is drawn from a fixed vocabulary - NEW, LIKE_NEW, GOOD, ACCEPTABLE - so that offers for the same title remain comparable.
- Monetary values are held in Indian Rupees to two decimal places, and every displayed amount states the currency.
- Timestamps are stored in UTC as ISO 8601 and rendered to the user in Indian Standard Time.
- A delivery address must carry a valid six-digit Indian PIN code.
- An order number follows the pattern OB-YYYYMMDD-nnnnnn and is unique for the lifetime of the system.

7. Other Requirements

7.1 Database Requirements

- The seventeen collections defined in Appendix B constitute the complete persistent schema. No collection may be added during implementation without a revision entry in this document.
- Unique indexes are required on USER.email, BOOK.isbn13 and ORDER.order_no. A compound text index over BOOK title, author, isbn13 and publisher supports FR-08.
- Referential integrity is enforced in the service layer, since MongoDB does not enforce it: no order line may reference a listing that does not exist, and no listing may reference a missing title or seller.
- Order lines store the unit price at the time of order, so that a later price change by the seller cannot alter a completed order.
- A daily automated backup is retained for seven days.

7.2 Legal and Compliance Requirements

- Personal data is limited to what the transaction requires - name, e-mail, phone and delivery address - and is never sold or shared with a third party beyond the payment gateway and the courier.
- A user may request deletion of their account; personal fields are then anonymised while the financial record of past orders is retained, as required for accounting.
- Card data never enters the system, so PCI-DSS obligations rest with the payment gateway.

7.3 Reuse Objectives

The authentication module, the notification module and the shared component library are written so that they carry no bookstore-specific assumption, and can be lifted into a later project without modification. This is a stated objective rather than an incidental outcome, and it is checked at code review.

Appendix A: Glossary

The terms, acronyms and abbreviations used throughout this specification are defined below.

Term	Meaning
Field layout	The definition of one persistent attribute: its name, maximum length, data type, description, whether it is mandatory, the rule that validates it, and an example value.
FK	Foreign key - an attribute referencing the primary key of another collection. Enforced in the service layer, not by the database.
GMV	Gross Merchandise Value - the total value of orders placed in a period.
Idempotent	An operation that produces the same result whether it is applied once or several times - required of the payment callback handler.
ISBN-13	International Standard Book Number, the thirteen-digit identifier printed on a book.
JWT	JSON Web Token, the signed token used to carry an authenticated session.
Listing	One seller's offer of one title, carrying its own condition, price and stock quantity. Several listings may exist for the same title.
Mandatory field	A field that must carry a value before the document is written, whether supplied by the user or generated by the system.
MERN	The MongoDB, Express.js, React and Node.js stack.
Offer	A listing as it appears to a buyer on the book detail page.
OTP	One-Time Password, the six-digit code used to verify an e-mail address.
RBAC	Role-Based Access Control - permission granted by the role a user holds.
RTM	Requirement Traceability Matrix - Appendix C.
Settlement	The amount payable to a seller after platform commission and returns are deducted.
Settlement window	The period between delivery and the release of a seller's payment, during which a return may still be raised.
SRS	This Software Requirements Specification.
System test case	A test exercising a complete user journey across several requirements, as distinct from a unit test case exercising one module in isolation.
Title / Book	A catalogue entry identified uniquely by ISBN-13, independent of any seller.
Traceability	The ability to follow a requirement forward to the design, code and test that satisfy it, and backwards from any of those to the requirement that justifies it.

Appendix B: Field Layouts and Report Requirements

The full data dictionary is supplied as the accompanying Excel workbook, Appendix_B_Field_Layouts_and_Reports.xlsx. It contains one sheet per collection, giving for every field its name, length, data type, description, mandatory flag, validation rule and a sample value; a Report Requirements sheet listing each report with its audience, frequency, parameters, output format and owner; and a Report Field Layouts sheet giving the columns each report prints, in print order. The workbook is the authoritative source; the tables below summarise it. Version 1.1 adds the CATEGORY, CART, WISHLIST, COUPON, AUDIT_LOG and SESSION collections, which the functional requirements already depended on.

B.1 Collections at a Glance

Collection	Purpose	Fields	Mand.	Key relationships
USER	Every person on the platform, with a role attribute distinguishing buyer, seller and administrator.	10	9	Owns ADDRESS, LISTING, CART, ORDER, REVIEW
ADDRESS	Delivery addresses saved by a buyer, one of them default.	9	7	Belongs to USER; referenced by ORDER
BOOK	Catalogue title, identified by ISBN-13, independent of any seller.	12	8	Classified by CATEGORY; offered as LISTING
LISTING	One seller's offer of one title, with its own condition, price and stock.	10	9	Joins BOOK and USER; referenced by cart and order lines
CART_ITEM	A line in a buyer's persistent cart.	6	6	Belongs to CART; references LISTING
ORDER	A confirmed purchase, with its money summary and lifecycle state.	11	9	Placed by USER; ships to ADDRESS
ORDER_ITEM	A line of an order, holding the price frozen at purchase.	8	8	Belongs to ORDER; references LISTING
PAYMENT	One payment attempt against an order, successful or otherwise.	9	7	Belongs to ORDER
SHIPMENT	A dispatched consignment with courier and tracking number.	9	7	Belongs to ORDER
REVIEW	A verified-purchase rating and comment against a title.	8	7	References BOOK, ORDER_ITEM and USER
NOTIFICATION	An outbound message and the outcome of its delivery.	8	8	Sent to USER
CATEGORY	Subject category for browsing and filtering, optionally nested under a parent.	4	3	Classifies BOOK; self-reference via parent_id
CART	The single persistent cart owned by a buyer.	4	4	Owned by USER (1:1); holds CART_ITEM

Collection	Purpose	Fields	Mand.	Key relationships
WISHLIST	A listing saved by a buyer for later purchase.	4	4	Belongs to USER; references LISTING
COUPON	A discount code with its type, value, validity and usage cap.	10	8	Applied to ORDER
AUDIT_LOG	Append-only record of every administrative action and payment event.	7	8	Actor is USER
SESSION	A refresh-token session, stored as a hash with a TTL expiry.	7	5	Belongs to USER

B.2 Sample Field Layout - USER

The layout below is reproduced from the workbook as an illustration of the format used for every collection.

Field	Length	Data Type	Description	Is Mandatory
_id	24	ObjectId	System-generated unique user identifier	Y
name	60	String	Full name of the registered user	Y
email	120	String	Login identifier; unique and RFC-5322 valid	Y
password_hash	60	String	Bcrypt hash at cost 12; plaintext never stored	Y
phone	10	Numeric	Contact number used for delivery updates	Y
role	10	String (enum)	BUYER, SELLER or ADMIN	Y
is_verified	1	Boolean	Set true once the e-mail OTP is confirmed	Y
is_blocked	1	Boolean	Set by an administrator to suspend the account	Y
created_at	8	Date	Timestamp at which the account was created	Y
last_login	8	Date	Timestamp of the most recent successful login	N

B.3 Reports Produced by the System

ID	Report	Primary user	Frequency	Output	Owner
RPT-01	Buyer Order History Report	Buyer	On demand	Screen, PDF	G H Pramod
RPT-02	Seller Sales and Settlement Report	Seller	Weekly, on demand	Screen, CSV, PDF	Hardhick M Gowda
RPT-03	Inventory and Low-Stock Report	Seller	Daily	Screen, CSV	Hardhick M Gowda
RPT-04	Payment Transaction Report	Administrator	Daily	CSV	G H Pramod
RPT-05	Platform Revenue and Growth Report	Administrator	Monthly	Screen, PDF	Hardhick M Gowda

ID	Report	Primary user	Frequency	Output	Owner
RPT-06	Catalogue Moderation Report	Administrator	On demand	Screen, CSV	Hardhick M Gowda

Sample Report Requirements: fields included in the report

Buyer Order History Report (RPT-01)	Seller Sales and Settlement Report (RPT-02)
Order Number	Order Number
Order Date	Order Date
Order Status	Book Title
Book Title	ISBN-13
Author	Quantity Sold
Seller Name	Sale Amount (INR)
Condition	Platform Commission (INR)
Quantity	Net Settlement (INR)
Unit Price (INR)	Settlement Status
Order Total (INR)	Buyer City
Payment Status	Remarks
Courier Tracking Number	

The remaining reports (RPT-03 to RPT-06) follow the same form; their column lists are in the Report Field Layouts sheet of the workbook.

Appendix C: Requirement Traceability Matrix

The complete matrix is supplied as the accompanying Excel workbook, Appendix_C_Requirement_Traceability_Matrix.xlsx. It carries all thirty-two requirements - FR-01 to FR-24 and NFR-01 to NFR-08 - each traced to its architecture component, design artefact, code file, unit test case and system test case, together with its type, priority, owner and status. A second sheet computes coverage per owner and confirms that no requirement is missing any reference; a third indexes the sixteen system test cases and the requirements each closes.

C.1 Coverage Summary

Team member	Functional	Non-functional	Total owned	High priority
Chenchu Sreekrishna Koushik (PES1UG24CS128)	6	2	8	5
Deeptha S (PES1UG24CS144)	6	2	8	5
G H Pramod (PES1UG24CS162)	6	2	8	5
Hardhick M Gowda (PES1UG24CS179)	6	2	8	3
Total	24	8	32	18

C.2 Extract from the Matrix

The first six rows are reproduced below to show the format; the workbook carries all thirty-two.

Sl. No	Requirement ID	Brief Description of Requirement	Architecture Reference	Design Reference	Code File Reference	Test Case ID	System Test Case ID
1	FR-01	Buyer and seller registration with server-side validation	Auth and User Service	SAD 3.4, 4.2.1	server/routes/auth.routes.js	TC-A-01	STC-01
2	FR-02	E-mail OTP verification before activation	Auth Service, Notification	SAD 3.4, 4.2.1	server/services/otpService.js	TC-A-02	STC-01
3	FR-03	Login and logout with access and refresh tokens	Auth and User Service	SAD 3.4, 4.2.1	server/middleware/verifyJWT.js	TC-A-03	STC-02
4	FR-04	Password recovery through a single-use reset link	Auth Service, Notification	SAD 4.3	server/services/authService.js	TC-A-04	STC-02
5	FR-05	Profile and delivery address book maintenance	Auth and User Service	SAD 4.3	server/models/Address.js	TC-A-05	STC-03
6	FR-06	Role-based access control on every protected route	Auth Service middleware	SAD 3.9	server/middleware/authorizeRoles.js	TC-A-06	STC-03

C.3 System Test Cases

ID	Scenario	Requirements closed
STC-01	Sign-up, OTP activation and duplicate e-mail rejection	FR-01, FR-02
STC-02	Login, token refresh, logout and password recovery	FR-03, FR-04
STC-03	Profile and address maintenance; cross-role call refused	FR-05, FR-06
STC-04	Catalogue paging and keyword search accuracy	FR-07, FR-08
STC-05	Filter and sort combinations; detail page with several offers	FR-09, FR-10
STC-06	Review permitted only after delivery; recommendations shown	FR-11, FR-12
STC-07	Cart survives logout; wishlist item moved to cart	FR-13, FR-14
STC-08	Checkout with coupon; sandbox payment success and forced failure	FR-15, FR-16
STC-09	Invoice e-mailed; order tracked; cancellation window enforced	FR-17, FR-18
STC-10	Listing created from ISBN lookup; low-stock alert raised	FR-19, FR-20
STC-11	Order fulfilled to dispatch; dashboard totals reconcile	FR-21, FR-22
STC-12	Administrator moderation and analytics export	FR-23, FR-24
STC-13	Search load test at reference load; availability monitoring	NFR-01, NFR-02
STC-14	Security scan with TLS verification; responsive walkthrough	NFR-03, NFR-04
STC-15	Concurrent purchase of the last copy; CI quality gate	NFR-05, NFR-06
STC-16	Cross-browser regression; audit log verification	NFR-07, NFR-08